EWB COURSES

AI-POWERED CYBERSECURITY

CYBERSECURITY

ASSESSMENT 01

Submitted by: Kaneez Aliya

Batch: 01

Course: Cyber Security

Assessment: 01

Submission date: 25 October 2026

Task A: Secure a student account

A1: Five distinct risk and asset and how CIA could be effected

1. Weak and reused password

- Risk: Mira uses the same short password for her email and learning portal. If someone discovers it, they may access both accounts.
- Asset: Email account, learning portal, and personal information.
- CIA impact — Confidentiality: Her private information may be seen by an unauthorised person.

2. Outdated software

- Risk: Mira delays software updates, which may leave security weaknesses in her laptop.
- Asset: Laptop, personal information, and project files.
- CIA impact — Confidentiality, Integrity, and Availability: An attacker may access private information, change files, or disrupt access to the laptop.

3. Friend using the laptop while Mira is signed in

- Risk: Her friend may see private information or accidentally change her files.
- Asset: Personal information, accounts, and project files.
- CIA impact — Confidentiality and Integrity: Her private information may be exposed, or her files may be changed without permission.

4. Approving unexpected sign-in prompts

- Risk: Mira may approve a sign-in request made by someone trying to access her account.
- Asset: Email account, learning portal, and personal information.
- CIA impact — Confidentiality: An unauthorised person may gain access to her private information.

5. Keeping only one copy of project files

- Risk: Mira may lose her project if her laptop is damaged or the files are deleted.
- Asset: Project files and academic work.
- CIA impact — Availability: She may be unable to access her project when she needs it.

A2: Control of each risk ,Limitations and first three action

1. Weak and reused password

- Control: Mira should use a long, strong, unique password for each account.
- Why it helps: If one password is discovered, the other account will still have a different password.
- Limitation: A strong password cannot fully protect an account if Mira shares it or approves an unauthorised sign-in.

2. Outdated software

- Control: Mira should install security updates regularly or enable automatic updates.
- Why it helps: Updates fix known security weaknesses in the software.
- Limitation: Updates cannot protect against every new threat or every type of attack.

3. Friend using the laptop while Mira is signed in

- Control: Mira should lock her laptop or sign out before leaving it with someone else.
- Why it helps: It prevents other people from easily accessing her accounts and files.
- Limitation: If someone knows her password, they may still be able to access the laptop.

4. Approving unexpected sign-in prompts

- Control: Mira should deny unexpected prompts and report repeated requests.
- Why it helps: This reduces the chance of accidentally allowing an unauthorised person into her account.
- Limitation: Denying a prompt does not remove the attacker's ability to keep trying.

5. Keeping only one copy of project files

- Control: Mira should keep a separate backup of her project files.

- Why it helps: She can recover her work if her laptop is damaged or files are lost.
- Limitation: If the backup is outdated or also gets damaged, she may lose recent work.

First three action to be prioritize :

Priority	Action	Why this order?
1	Deny unexpected sign-in prompts	This reduces the immediate risk of allowing unauthorised account access.
2	Change reused passwords	This helps protect both accounts if the old password has been discovered.
3	Lock the laptop or sign out	This helps protect private information and files from unauthorised access.

A3: Authentication and authorization :

1. Authentication — Who are you?

Authentication is the process of checking a user's identity.

Example: Mira enters her username and password to log in to her learning portal. The portal checks whether her login details are correct.

2. Authorization — What are you allowed to access?

Authorization determines what an authenticated user is permitted to do.

Example: After Mira logs in, the portal allows her to view her course materials, submit assignments, and check her marks. However, she cannot access the teacher's account or change other students' marks unless she has the required permission.

Task B: Analyse a Suspicious Message

B1

. Five Warning Signs

1. Urgent deadline: The subject says “FINAL WARNING” and claims the scholarship expires in 20 minutes. This creates pressure and may make the student act without checking.

2. Different Reply-To address: The sender uses awards@campus-awards.example, but the Reply-To address is help@personal-awards.example. This difference needs verification.

3. Request for password and OTP: The message asks for the college password and OTP. These are sensitive login details that should not be shared through an email link.

4. Discouraging verification: The message says not to contact the college office. This prevents the student from independently checking whether the scholarship is genuine.

5. Request for identity card photo: The sender asks for a photo of the student's identity card. Sharing it with an unverified sender could expose personal information.

B2. Safe Verification Process

I would not click the link or reply to the message. I would independently open the college's official portal or contact the scholarship office using verified contact details. I would ask whether the scholarship notification is genuine. HTTPS only means the connection is encrypted; it does not prove that the website belongs to the real college. A familiar display name can also be misleading.

B3. Response Plan if a Password and OTP Were Entered

1. Immediately contact the college's official IT support and report the incident.
2. From a trusted device, change the affected password and any reused passwords. Follow IT support's advice to secure the account and sign out other sessions.
3. Check recent sign-ins and account changes, and report any suspicious activity. Do not share the password or OTP with anyone.

B4. One Fact That Cannot Be Established

The message alone cannot prove whether the scholarship has actually been approved. I would verify this through the official college portal or scholarship office and request confirmation through an independently verified contact method.

Task C: Triage a Sign-in Alert

C1. Four-Point Timeline

1. 09:00–09:01: The log shows a successful password sign-in followed by MFA approval from the usual classroom IP address, 192.0.2.10. This appears to be a normal sign-in.

2. 10:14–10:16: Two password attempts failed, followed by a successful password sign-in from 198.51.100.23. This could indicate that someone eventually entered a valid password.

3. 10:17–10:20: An MFA request was denied, another was approved, and a session was created. These events suggest that access was granted after the MFA approval.

4. User statement: The student says they did not sign in after 09:05 but approved a prompt around 10:18, believing it would stop repeated requests. This raises concern that the later session may not have been authorised.

C2. Likely and Alternative Explanations

Likely explanation: Someone may have tried to access the account using a password and obtained access after the student approved an unexpected MFA prompt.

Alternative explanation: The student may have unknowingly initiated or continued a sign-in process on another device or network. The available evidence does not prove who used the IP address.

Two additional checks:

1. Review the account's device, session, and sign-in history.
2. Check with the student and review available authentication records to understand where the MFA requests originated.

C3. Three Prioritised Response Actions

1. Secure the account: The authorised IT team should reset the compromised password, revoke active sessions, and review MFA settings.

2. Preserve evidence: Save the relevant sign-in and authentication logs before they are lost or changed. This helps the team investigate the incident.

3. Investigate and monitor: Review sign-in records, check for account changes, and monitor for further suspicious activity.

C4. Incident Summary

The sign-in log records two failed password attempts from 198.51.100.23, followed by a successful password sign-in, an MFA denial, an MFA approval, and session creation. The student says they did not sign in after 09:05 but approved a prompt around 10:18. This suggests possible unauthorised account access, although the log does not identify the person behind the IP address. The IT team should secure the account, preserve the logs, and investigate the sign-in and authentication records.

Task D: Review an AI Security Answer

D1. Five Unsafe or Unsupported Claims

1. HTTPS means the email is safe. HTTPS encrypts the connection but does not prove that a website or email is genuine. The sender and website should be independently verified.

2. The IP address proves who stole the password. An IP address alone cannot identify a specific person. Additional sign-in records and investigation are required.

3. MFA prevents every account compromise. MFA adds protection but does not prevent every attack, especially when a user approves an unexpected prompt.

4. Suspicious logs should be deleted. Logs should be preserved because they provide evidence that can help the IT team investigate the incident.

5. The student's password should be sent to support. Passwords must not be shared. The student should change a potentially compromised password and contact official IT support.

D2. A Better AI Prompt

Analyse only the fictional email and sign-in log provided. Separate observed facts from assumptions, identify possible security risks, and recommend safe actions. Do not identify a person from an IP address or request passwords, OTPs, or other private information. Clearly state uncertainty and explain what additional evidence would be needed.

D3. Corrected Security Advice

The email and sign-in log should be reviewed carefully before drawing conclusions. HTTPS does not prove that an email or website is genuine, and an IP address alone cannot identify an attacker. The repeated failed sign-ins, later successful password attempt, MFA denial, MFA approval, and session creation raise concern about possible unauthorised access. The IT team should secure the account by resetting the password, revoking active sessions, and reviewing MFA settings. Relevant logs should be preserved for investigation rather than deleted. The student should report the incident through official IT support and check for suspicious account changes. Passwords and OTPs must never be sent to support. Further sign-in and authentication records should be reviewed before deciding what happened.

D4. AI-Use Declaration and References

AI-use declaration: AI-Use Declaration

I used ChatGPT to understand the questions and get ideas for my answers. I used its guidance to organise my work and explain the topics in simple words. I reviewed the content and prepared my final report.

Reference 1: CISA, *Secure Our World* — https://www.cisa.gov/secure-our-world

Reference 2: NIST, *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (AI 600-1)* — https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

THANK YOU!